TS ACADEMY CYBERSECURITY CAPSTONE

TASK 2: VULNERABILITY RISK ASSESSMENT

From Vulnerability to Compliance: Securing Legacy and Cloud Systems at HanTech

Assessment target	Metasploitable 2
Target IP address	192.168.43.12
Scanner	Nmap 7.99 service/version detection (-sV)
Assessment date	5 November 2026
Student / Group	_____

This report assesses the potential risks associated with the five services identified during the Task 1 scan. No exploitation was performed.

1. Assessment summary

The scan confirmed that the target host was reachable and that all five assigned services were listening. The highest-priority concern is the legacy Apache service because CVE-2011-3192 affects Apache HTTP Server 2.2.8 and can cause remote denial of service. Samba also presents a potentially serious command-execution risk if the installed build and vulnerable configuration conditions are present. PostgreSQL may allow an authenticated user to gain additional privileges if the server is running an affected release.

Risk rating approach: Likelihood and impact are qualitative judgments for this lab environment. The overall rating considers the CVE severity, whether the service is reachable, and any known prerequisites. CVSS versions differ across older CVE records, so scores from different CVSS versions should not be compared as if they were calculated on one identical scale.

2. Risk assessment table

No. / Service	Detected version / port	Relevant CVE and CVSS	Likelihood	Impact	Risk rating	Reason / potential attacker goal
1. OpenSSH	4.7p1 Debian 8ubuntu1 TCP 22	CVE-2008-5161 CVSS 3.1: 3.7 (Low)	Medium	Low–Medium	Medium	CBC-mode SSH connections may expose limited plaintext information. An attacker could attempt to infer sensitive session data. The enabled cipher list was not checked.
2. Apache HTTP Server	2.2.8 (Ubuntu), DAV/2 TCP 80	CVE-2011-3192 CVSS 3.0: 7.5 (High)	High	High	High	Vulnerable Range-header handling can consume excessive CPU and memory, causing denial of service. Apache lists 2.2.8 among affected versions.
3. Samba (smbd)	Nmap: 3.X–4.X TCP 139, 445 CLI check: 3.0.20	CVE-2007-2447 CVSS 2.0: 6.0 (Medium)	Medium–High	High	High	Samba 3.0.0–3.0.25rc3 is affected by an MS-RPC command-injection flaw under specified conditions. Successful exploitation could allow command execution.
4. PostgreSQL	Nmap: 8.3.0–8.3.7 TCP 5432	CVE-2009-3230 CVSS 2.0: 6.5 (Medium)	Medium	High	High	The flaw involves misuse of RESET SESSION AUTHORIZATION and can allow privilege escalation. An attacker would need an authenticated database account.
5. ProFTPD	1.3.1 TCP 2121	CVE-2008-4242 CVSS 2.0: 6.8 (Medium)	Low–Medium	Medium	Medium	A crafted long ftp:// URI may abuse an existing browser FTP session to issue FTP commands. User interaction and a suitable browser session are required.

3. CVE and risk justification

OpenSSH – CVE-2008-5161

OpenSSH 4.7p1 is listed as potentially affected when a CBC-mode block cipher is used. The CVSS 3.1 score used here is 3.7 (Low). Likelihood is not rated High because the relevant cipher configuration has not been checked.

Apache – CVE-2011-3192

The Apache HTTP Server project lists version 2.2.8 among the affected versions. Specially crafted overlapping Range headers can cause high CPU and memory use. The CVSS 3.0 score is 7.5 (High), supporting a High risk rating for a network-accessible web service.

Samba – CVE-2007-2447

The Samba advisory identifies versions 3.0.0 through 3.0.25rc3 as affected. The flaw can permit command execution through MS-RPC under specified conditions. The CVSS v2 score is 6.0 (Medium), but the possible system-level impact supports a High contextual risk rating.

PostgreSQL – CVE-2009-3230

PostgreSQL lists 8.3.8 as the fixed release for CVE-2009-3230. The issue concerns misuse of RESET SESSION AUTHORIZATION and can allow an authenticated user to gain privileges. The CVSS v2 score is 6.5 (Medium); the possible effect on database confidentiality and integrity supports a High contextual rating.

ProFTPD – CVE-2008-4242

ProFTPD 1.3.1 is named in this CVE. It concerns browser-based FTP cross-site request forgery and the execution of FTP commands through a long ftp:// URI that uses an existing browser FTP session. The CVSS v2 score is 6.8 (Medium), while the user-interaction requirement reduces the assessed likelihood.

4. Overall conclusion

The scan shows a set of legacy services running on the Metasploitable 2 host. Apache is the clearest High-risk finding because the detected version is listed as affected by a denial-of-service vulnerability. Samba and PostgreSQL also need attention because the cited issues could have serious consequences. OpenSSH and ProFTPD are rated Medium because their weaknesses have additional conditions or require user interaction. In a production environment, the recommended response would be to upgrade unsupported software, restrict access to administrative and database services, disable unnecessary services, and apply security updates.

5. References

• NVD / CISA-ADP, CVE-2008-5161: https://nvd.nist.gov/vuln/detail/CVE-2008-5161
• Apache HTTP Server Project, 2.2 vulnerability advisories (CVE-2011-3192): https://httpd.apache.org/security/vulnerabilities_22.html
• Samba Project, CVE-2007-2447 security announcement: https://www.samba.org/samba/security/CVE-2007-2447.html
• PostgreSQL, Security Information for version 8.3 (CVE-2009-3230): https://www.postgresql.org/support/security/8.3/
• Debian Security Tracker, CVE-2008-4242: https://security-tracker.debian.org/tracker/CVE-2008-4242
• NVD, CVE-2009-3230: https://nvd.nist.gov/vuln/detail/CVE-2009-3230